

ניתוח טופולוגי של סיכונים בשרשראות אספקת תוכנה באמצעות אלגוריתמים בגרפים

צוות הפרויקט

רון בלנקי - 207720897, מוטי סחרטוב - 322355504, עידן דהן - 207758541

GitHub Repository:
[לחץ](#)

Google Colab Notebook:
[לחץ](#)

Google Docs:
[לחץ](#)

1. מבוא, מוטיבציה והגדרת הבעיה

פיתוח תוכנה מודרני מבוסס במידה רבה על שימוש חוזר בקוד קיים. במקום לממש כל רכיב מחדש, מפתחים משלבים בפרויקטים ספריות וחבילות קוד פתוח המספקות יכולות מוכנות. שיטה זו מקצרת את זמן הפיתוח ומאפשרת לבנות מערכות מורכבות, אך היא גם יוצרת תלות במספר רב של רכיבים חיצוניים.

חבילה שמותקנת בפרויקט עשויה להיות תלויה בחבילות נוספות, שגם הן תלויות בחבילות אחרות. לדוגמה, אם חבילה A תלויה בחבילה B, וחבילה B תלויה בחבילה C, הפרויקט המשתמש ב-A מסתמך בפועל גם על B ועל C. כך נוצרת שרשרת של תלויות ישירות ועקיפות המכונה שרשרת אספקת תוכנה.

ככל שמספר החבילות גדל, קשה יותר להבין באופן ידני את מבנה התלויות המלא. מפתח עשוי לבחור מספר קטן של חבילות ישירות, אך התקנתן יכולה להוסיף מאות ואף אלפי תלויות עקיפות שהוא לא בחר במפורש ולעיתים אינו מודע לקיומן. מצב זה יוצר סיכון אבטחתי, משום שפגיעה בחבילה אחת עלולה להשפיע על רכיבים ופרויקטים רבים התלויים בה.

הסיכון של חבילה אינו נקבע רק לפי קיומה של פגיעות. שתי חבילות עשויות להכיל פגיעות באותה רמת חומרה, אך להיות שונות מבחינת מיקומן בתוך רשת התלויות. חבילה אחת יכולה להיות שולית יחסית, בעוד שחבילה אחרת משמשת תלות משותפת למספר רב של רכיבים או מחברת בין אזורים שונים של הרשת. לכן, מידע על פגיעויות בלבד אינו תמיד מספיק לצורך הערכת ההשפעה המערכתית האפשרית.

ניתן לייצג את מערכת התלויות כגרף מכוון. כל חבילה מיוצגת באמצעות צומת, וכל תלות בין חבילות מיוצגת באמצעות קשת. ייצוג זה מאפשר להשתמש באלגוריתמים בגרפים כדי לזהות צמתים מרכזיים, לאתר גשרים בין חלקים שונים של המערכת, לזהות קהילות ולבחון את החוסן המבני של הרשת.

בחרנו ב-Flowise 3.1.2 כמקרה בוחן משום שהיא נשענת על עץ תלויות רחב באקוסיסטם npm (מאגר החבילות המרכזי של JavaScript ו־Node.js). במסגרת ההרצה הסופית נבדקו 2,548 צירופי חבילה-גרסה, כלומר שם חבילה יחד עם הגרסה המדויקת שנבחרה בפועל בפתרון התלויות, לדוגמה `axios@1.7.7`.

עושר זה של תלויות ומידע אבטחתי מאפשר לבחון לא רק אילו גרסאות מושפעות מפגיעויות מוכרות, אלא גם האם החבילות שאליהן הן שייכות ממלאות תפקידי גשר או תשתית מרכזיים ברשת. מטרת הבחירה אינה להוכיח מראש שניתן לפרוץ ל-Flowise, אלא לבחון כיצד חומרת הפגיעות ומרכזיותה הטופולוגית של החבילה יכולות לשמש יחד לצורך תעודף סיכונים.

מטרתנו היא לבחון כיצד המיקום הטופולוגי של חבילה בתוך רשת התלויות יכול לספק מידע נוסף על חשיבותה המערכתית. באמצעות מדדי מרכזיות, זיהוי קהילות, השוואה לגרף אקראי וסימולציות של הסרת צמתים, אנו בוחנים האם ניתוח גרפים יכול לסייע בתעודף חבילות לבדיקה, ניטור והגנה.

1.1 שאלות המחקר

העבודה נבנתה סביב ארבע שאלות מחקר:

1. אילו חבילות ממלאות תפקידי גשר ותשתית מרכזיים בגרף, והאם מדדי מרכזיות שונים מזהים את אותן חבילות?
2. כיצד הרשת מתחלקת לקהילות מבחינה מבנית, ואילו קשתות ממלאות תפקיד מרכזי בחיבור בין אזורים שונים ובתוך קהילת הליבה?
3. במה שונה המבנה הגלובלי של רשת התלויות מהרכב של גרפים אקראיים בעלי אותו מספר צמתים וקשתות, והאם הרשת מציגה מאפייני Small-World והתפלגות דרגות בעלת זנב כבד?
- 4 א. האם הסרה ממוקדת של חבילות בעלות Betweenness גבוהה פוגעת בקשירות יותר מהסרה אקראית של אותו מספר חבילות?
- 4 ב. האם גרסאות התלות המושפעות security advisories מוכרים (רשומות אבטחה המתארות פגיעויות שפורסמו) שייכות לחבילות בעלות מרכזיות טופולוגית גבוהה, באופן המצדיק עדיפות גבוהה יותר בבדיקה ובהגנה?

2. עבודה קשורה

- Zimmermann ואחרים ניתחו את אקוסיסטם npm כרשת של חבילות, תלויות ומתחזקים. הם מצאו שמספר מצומצם יחסית של חבילות ומתחזקים עשוי להשפיע על חלק גדול מהאקוסיסטם. המחקר רלוונטי לעבודתנו משום שהוא מדגים כיצד ריכוזיות ברשת תלויות תוכנה יכולה ליצור נקודות כשל בעלות השפעה רחבה [1].
- Ohm ואחרים חקרו 174 חבילות זדוניות שנמצאו באקוסיסטמים כמו npm, PyPI ו-RubyGems. המחקר סיווג את הדרכים שבהן תוקפים מכניסים קוד זדוני לחבילות ואת השלבים שבהם הקוד עשוי לפעול במערכות המשתמשים. עבודה זו מדגישה כי יחסי התלות ומנגנוני ההתקנה האוטומטיים יכולים לשמש ערוץ להפצת קוד זדוני [2].
- Barabási-Albert, Jeong השוו בין כשלים אקראיים לבין הסרה ממוקדת של צמתים מרכזיים ברשתות מורכבות. עבודה זו מספקת את הבסיס המתודולוגי לניסוי החוסן שלנו, שבו השווינו הסרה אקראית של חבילות להסרה ממוקדת לפי Betweenness Centrality [3].
- נוסף על המחקרים האקדמיים, בחנו אירועים אמיתיים הממחישים את הסיכון שבפגיעה בחבילות מהימנות. במרץ 2026 פורסמו גרסאות זדוניות של Axios לאחר השתלטות על חשבון npm של מתחזק. לגרסאות נוספה תלות זדונית, והן היו זמינות במאגר למשך מספר שעות לפני שהוסרו. המקרה רלוונטי לעבודתנו משום שהוא מדגים כיצד פגיעה בחבילה מוכרת ובעלת שימוש רחב עלולה ליצור השפעה החורגת מהחבילה עצמה [4].
- במסגרת Arch Atomic Arch השתלטו תוקפים על בחבילות נטושות אך מהימנות ב-AUR (מאגר חבילות קהילתי של Arch Linux) ושינו את הוראות הבנייה שלהן כך שיתקינו תלות npm זדונית. המקרה מדגים כי תוקף אינו חייב לבנות אמון מאפס; הוא יכול לרשת את האמון הקיים סביב חבילה ולהשתמש בה כערוץ הפצה [5].
- המחקרים והאירועים המתוארים מציגים שני צדדים משלימים של הבעיה. מחקרים קודמים מראים שרשתות תוכנה עשויות להיות מרוכזות סביב מספר קטן של חבילות ופגיעה מכוונת בצמתים מרכזיים יכולה להיות משמעותית יותר מכשל אקראי. האירועים המעשיים מראים כיצד תוקפים מנצלים בפועל חבילות וחשבונות מהימנים. עבודתנו מחברת בין הצדדים באמצעות ניתוח של מקרה מבחן קונקרטי: אנו בוחנים האם מיקומן הטופולוגי של חבילות בגרף התלויות של Flowise יכול לשמש שכבת תעדוף משלימה למידע אבטחתי קיים.

3. מודל, אלגוריתמים ושיטת העבודה

3.1 איסוף הנתונים ומידול הגרף

הנתונים נאספו באמצעות ה-API של Google Open Source Insights, המוכר גם בשם [deps.dev](https://github.com/deps-dev) [8]. השירות מספק גרף תלויות פתור עבור גרסה מוגדרת של חבילת תוכנה, וכולל תלויות ישירות ועקיפות.

לצורך הפרויקט נשלף מ־[deps.dev](https://github.com/deps-dev) גרף התלויות של Flowise בגרסה 3.1.2. תגובת ה-API נשמרה כ־snapshot מקומי קבוע, ששימש את ההרצה הסופית ואת כלל שלבי הניתוח.

הגרף נבנה באמצעות ספריית [NetworkX](#) [9] כגרף מכון מסוג [DiGraph](#). כל צומת מייצג חבילת תוכנה. קשת מכונת מהצומת A אל הצומת B מציינת כי החבילה A תלויה בחבילה B. הקשר אינו סימטרי: העובדה ש-A זקוקה ל-B אינה אומרת ש-B זקוקה ל-A.

חשוב להבחין בין כיוון קשת התלות לבין כיוון ההשפעה האפשרי של פגיעה. הקשת מצביעה מהחבילה המשתמשת אל החבילה שבה היא משתמשת. לעומת זאת, אם B נפגעת, ההשפעה עשויה להיות מורגשת אצל A ואצל חבילות אחרות התלויות ב-B.

לצורך הניתוח הטופולוגי אוחדו רשומות בעלות אותו שם חבילה לצומת יחיד. במקביל נשמרו 2,548 זוגות של (חבילה-גרסה) ייחודיים לצורך הניתוח האבטחתי. עבור כל זוג מדויק נשלפו מ־`deps.dev` מזהי ה־`advisories` הידועים כמשפיעים ישירות על אותה גרסה [8]. מזהי ה־`GHSA` (מזהים ייחודיים של רשומות אבטחה ב־`GitHub`) מקושרים ל־`GitHub Advisory Database` [14] ופרטי החומרה וציוני `CVSS` (סולם מספרי מ־0 עד 10 להערכת חומרת פגיעות) נשלפו מ־`OSV` (מאגר פתוח של פגיעויות בקוד פתוח).

כך איתור הפגיעויות מתבצע ברמת הגרסה, בעוד שמדדי המרכזיות מתארים את תפקידה הכולל של החבילה ברשת [15].

3.2 מסגרת הניתוח

הניתוח בוצע בארבע שכבות משלימות. תחילה חישבנו `Betweenness Centrality`, `Harmonic Centrality` ו־`PageRank` כדי לזהות סוגים שונים של חשיבות טופולוגית. את הדמיון בין הדירוגים בחנו באמצעות מתאם `Spearman`.

לאחר מכן השתמשנו ב־`Greedy Modularity` לזיהוי אזורים מבניים ברשת `Edge Betweenness` [6]. שימש לאיתור קשרי גשר גלובליים ופנימיים, ו־`Girvan-Newman` שימש לבחינת החלוקה ההיררכית הראשונה של ההטלה הלא־מכוונת [7].

ברמה הגלובלית חישבנו צפיפות, `In-Degree` ומקדם התקבצות. התוצאות הוששו ל־50 גרפי `Erdős-Rényi` בעלי אותם מספרי צמתים וקשתות, כדי לבדוק אם ריכוז ה־`hubs` וההתקבצות יכולים להיות מוסברים באמצעות פיזור אקראי של הקשתות. לאחר מכן בחנו מאפייני `Small-World` באמצעות השוואת מקדם ההתקבצות ואורך המסלול הממוצע לרשתות האקראיות וחישבו המקדם σ [10], [11]. לבסוף התאמנו לזנב התפלגות ה־`In-Degree` מודל ה־`Power Law` והשוונו אותו סטטיסטית ל־`Lognormal` ול־`Exponential` באמצעות `Maximum Likelihood` ויחס נראות [12], [13].

לבסוף ביצענו סימולציית חוסן שבה הושוותה הסרה ממוקדת של 50 חבילות לפי `Betweenness` לממוצע של 100 הסרות אקראיות. במקביל נותחו אוטומטית כל 2,548 זוגות החבילה-גרסה שנפתרו עבור `Flowise`. החבילות שהגרסאות שלהן הושפעו מ־`advisories` דורגו ביחס לכל 2,138 החבילות, ונבדקה סטטיסטית מידת ההעשרה שלהן בעשירון וברבעון העליון של דירוג `Betweenness` [8], [15].

4. תוצאות וממצאים

4.1 מאפייני מערך הנתונים והגרף

בתגובת ה־`API` התקבלו 3,061 רשומות צמתים ו־6,645 רשומות קשתות. מאחר שמספר רשומות עשויות לייצג גרסאות שונות או מופעים שונים של אותה חבילה, הרשומות אוחדו לפי שם החבילה לצורך הניתוח הטופולוגי. לאחר האיחוד התקבל גרף מכון ובו 2,138 צמתי חבילות ייחודיים ו־5,016 קשתות ייחודיות.

הצפיפות שהתקבלה הייתה 0.001098 בלבד. משמעות הדבר היא שחלק קטן מאוד מכל קשרי התלות האפשריים אכן מתקיים, ולכן הרשת דלילה מבחינה גלובלית. עם זאת, הדלילות אינה מעידה על חלוקה אחידה של הקשרים: ה־`In-Degree` הממוצע היה 2.35, בעוד שה־`In-Degree` המרבי הגיע ל־125. פער זה מצביע על כך שמרבית החבילות מקבלות מספר קטן של קישורים נכנסים, בעוד שמספר מצומצם של חבילות משמש תשתית משותפת לחלקים רבים של האקוסיסטם.

מקדם התקבצות בהטלה הלא־מכוונת: 0.236507. ערך זה גבוה ביחס לצפיפות הרשת ומצביע על קיומן של קבוצות מקומיות שבהן חבילות מקושרות זו לזו במידה גבוהה יותר מכפי שהיה צפוי מרשת בעלת פיזור אקראי לחלוטין.

תוצאה	מדד
3,061	רשומות צמתים שהתקבלו מה־API
2,138	שמות חבילות ייחודיים
6,645	רשומות קשתות שהתקבלו מה־API
5,016	קשתות ייחודיות
0.001098	צפיפות
2.346118	In-Degree ממוצע
125	In-Degree מרבי
0.236507	מקדם התקבצות ממוצע
33	מספר קהילות
474	גודל הקהילה הגדולה

טבלה 1: מאפייניו המרכזיים של גרף התליות לאחר איחוד הרשומות לפי שם החבילה.

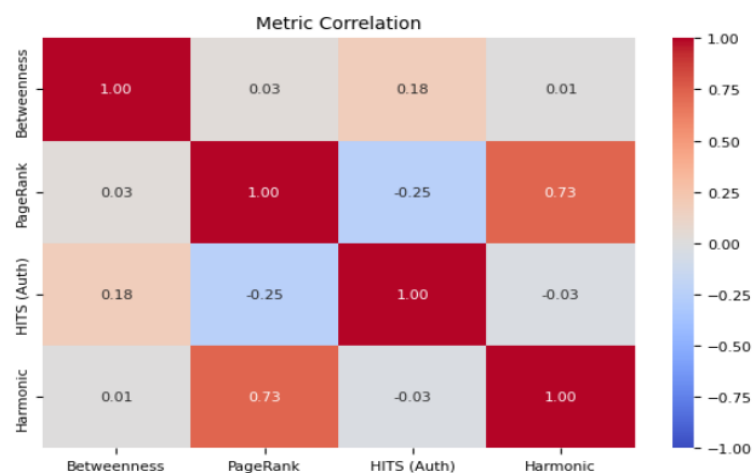
4.2 חבילות מרכזיות והשוואה בין מדדי המרכזיות

מדדי המרכזיות זיהו שני סוגים עיקריים של חשיבות. Betweenness Centrality הדגיש חבילות גשר הנמצאות על מספר גדול של מסלולים קצרים:

yargs; @grpc/proto-loader; form-data; grpc/grpc-js@; readable-stream

לעומתו, Harmonic Centrality, PageRank ו־HITS הדגישו בעיקר חבילות תשתית, ובהן tslib ו־debug. מתאם Spearman בין PageRank ל־Harmonic היה 0.73, בעוד שהמתאם בין Betweenness ליתר המדדים נע בין 0.01 ל־0.18 בלבד.

הממצא מראה שאין דירוג מרכזיות יחיד המתאר את כל סוגי החשיבות. Betweenness מזהה חבילות גשר, ואילו המדדים האחרים מדגישים נגישות, שימוש חוזר וסמכות מבנית. לכן שילוב המדדים מספק תמונת סיכון רחבה יותר מדירוג יחיד.



איור 1: מתאם Spearman בין מדדי המרכזיות PageRank ו-Harmonic Centrality מציגים דמיון יחסי, בעוד ש-Betweenness Centrality כמעט שאינו מתואם עם יתר המדדים.

4.3 מבנה הקהילות והקשרים הקריטיים

Greedy Modularity חילק את הרשת ל-33 קהילות. הקהילה הגדולה כללה 474 חבילות, כ-22% מכלל הרשת, ואחריה קהילות בגודל 152, 144, 139 ו-138 חבילות. Edge Betweenness הגלובלי זיהה את הקשת מ-@grpc/proto-loader אל yargs כקשר הגשר הבולט ביותר. בתוך הקהילה הגדולה בלטה הקשת מ-flowise אל flowise-components. החלוקה הראשונה של Girvan-Newman פיצלה את ההטלה הלא-מכוונת לקבוצות בגודל 2,079 ו-59 חבילות. יחד, הממצאים מראים שהרשת כוללת קהילת ליבה גדולה לצד אזורים קטנים יותר המחוברים באמצעות מספר מצומצם של קשרים מרכזיים.

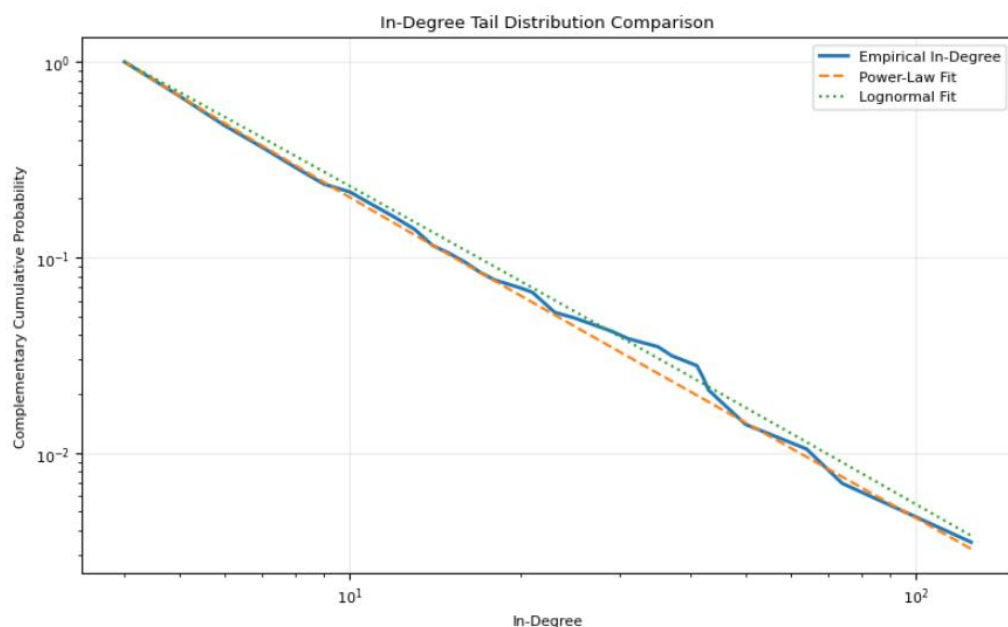
4.4 מבנה לא-אקראי, Small-World והתפלגות זנב כבד

הרשת הושוותה ל-50 גרפי Erdős-Rényi, שכל אחד מהם כלל 2,138 צמתים ו-5,016 קשתות. ממוצע ה-In-Degree היה זהה מכוח אופן בניית קו הבסיס. לעומת זאת, ה-In-Degree המרבי ברשת Flowise היה 125, בעוד שהממוצע בגרפים האקראיים היה 9.38 עם סטיית תקן של 1.01. מקדם ההתקבצות של הרשת היה 0.236507, לעומת ממוצע של 0.001974 בקו הבסיס. אף אחד מ-50 הגרפים האקראיים לא הגיע לערכים האמפיריים, ובשני המדדים התקבלה הסתברות אמפירית של 0.0196.

לצורך בדיקת Small-World חושבו המדדים על רכיב הקשירות הגדול ביותר. מקדם ההתקבצות ברשת היה 0.236507, לעומת 0.001991 בממוצע בגרפים האקראיים, ולכן יחס ההתקבצות היה 118.759. אורך המסלול הממוצע היה 5.171989, לעומת 5.121780 בגרפים האקראיים, יחס של 1.0098. בהתאם לכך התקבל מקדם Small-World של $\sigma = 117.606$.

בניתוח זנב התפלגות ה-In-Degree התקבל מעריך $\alpha = 2.6105$, כאשר ההתאמה החלה ב- $x_{\min} = 4$ וכללה 287 תצפיות. בהשוואת הנראות, מודל Power Law התאים לזנב טוב יותר באופן מובהק ממודל Exponential ($R = -0.0282$, $p = 0.000494$). לעומת זאת, לא התקבל הבדל מובהק בין Power Law ל-Lognormal ($R = 0.512058$, $p = 0.512058$). לכן התוצאות תומכות בתיאור ההתפלגות כבעלת זנב כבד, אך אינן מאפשרות לקבוע באופן חד-משמעי שהיא Power Law.

יחד, התוצאות מראות שרשת Flowise אינה מאורגנת כפיזור אקראי של קשרים. היא משלבת hubs גדולים, קהילות מקומיות צפופות, מסלולים גלובליים קצרים והתפלגות דרגות בעלת זנב כבד.



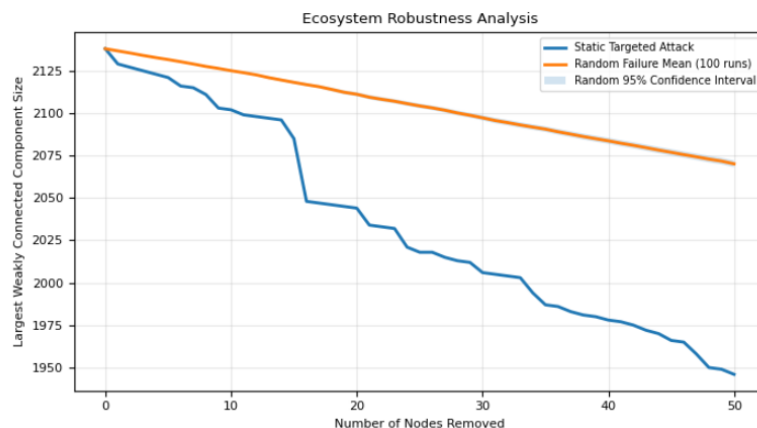
איור 2: השוואת זנב התפלגות In-Degree למודלי Power Law ו-Lognormal באמצעות CCDF (פונקציית ההתפלגות המצטברת המשלימה). CCDF מציג את ההסתברות שה-In-Degree של חבילה יהיה לפחות ערך נתון. שני המודלים עוקבים מקרוב אחר הנתונים האמפיריים, בעוד שמודל Power Law נמצא עדיף באופן מובהק על Exponential.

4.5 חוסן הרשת תחת הסרה ממוקדת ואקראית

בהסרה הממוקדת הוסרו 50 החבילות בעלות Betweenness הגבוה ביותר, שהן 2.34% בלבד מכלל הצמתים. הסרתן הקטינה את גודל רכיב הקשירות החלשה הגדול ביותר - LWCC, כלומר מספר הצמתים ברכיב הגדול ביותר כאשר מתעלמים מכיוון הקשתות - ב-8.98%.

בהשוואה, ב-100 הרצות של הסרת 50 צמתים אקראיים התקבלה ירידה ממוצעת של 3.17%, עם סטיית תקן של 0.48 נקודות אחוז. ההסרה הממוקדת הייתה אפוא הרסנית פי 2.83 מההסרה האקראית הממוצעת. ההסתברות האמפירית שהסרה אקראית תהיה הרסנית לפחות באותה מידה הייתה 0.0099.

הממצא מראה שקבוצה קטנה של חבילות גשר משפיעה באופן לא-פרופורציונלי על הקשירות המבנית של האקוסיסטם.



איור 3: השוואה בין הסרה ממוקדת סטטית לפי Betweenness Centrality לבין ממוצע של 100 הסרות אקראיות. התחום המוצל מייצג רווח סמך של 95% לקו הבסיס האקראי.

4.6 תעדוף פגיעויות ברמת גרסה באמצעות מרכזיות טופולוגית

בבדיקה האוטומטית נותחו 2,548 צירופי החבילה-גרסה שנפתרו עבור Flowise 3.1.2. עבור כל גרסה נשלפו ה-advisories הידועים כמשפיעים עליה ישירות. הבדיקה זיהתה 151 מזהי advisory ייחודיים, המשפיעים על 61 צירופי חבילה-גרסה ועל 47 שמות חבילות [8], [15].

מבין 47 החבילות המושפעות, 23 דורגו בעשירון העליון לפי Betweenness Centrality, לעומת 4.70 חבילות בלבד שהיו צפויות תחת בחירה אקראית. בדיקת ההעשרה ההיפרגאומטרית נתנה ערך של $p = 6.156 \times 10^{-12}$. בנוסף, 30 חבילות דורגו ברבעון העליון, לעומת 11.76 צפויות, עם $p = 1.473 \times 10^{-8}$.

התוצאות מצביעות על ריכוז מובהק של חבילות מושפעות בעמדות גשר מרכזיות. form-data דורגה במקום השלישי והושפעה מ-advisory בחומרת CRITICAL ובציון 4CVSS של 9.4. החבילה grpc/grpc-js@ דורגה במקום הרביעי. protobufs דורגה במקום 24 והגיעה לציון CVSS של 9.8, ואילו axios דורגה במקום 42 והושפעה מ-33 advisories.

הממצא מדגים את הערך המוסף של השיטה: advisory מזהה פגיעות המשפיעה על גרסה מדויקת, ואילו Betweenness Centrality מעריך את חשיבות החבילה למבנה האקוסיסטם. שילוב שני הממדים מאפשר להעניק עדיפות גבוהה יותר לפגיעויות המופיעות בחבילות גשר מערכתיות [8], [15].

בניסויי חקרני משלים, מדד Jaccard זיהה את `qs`, `tough-cookie` ו-`dotenv` כחבילות בעלות הסביבה המבנית הדומה ביותר ל-`form-data`; תוצאה זו לא שימשה בדירוג הסיכון המרכזי.

חבילה	Advisories	CVSS	חומרה	דירוג
form-data	2	9.4	CRITICAL	3
@grpc/grpc-js	2	7.5	HIGH	4
micromatch	1	5.3	MODERATE	12
protobufjs	11	9.8	CRITICAL	24
@modelcontextprotocol/sdk	1	7.6	HIGH	34
qs	3	6.3	MODERATE	36
braces	1	7.5	HIGH	38
axios	33	8.7	HIGH	42
tar-fs	3	8.7	HIGH	46
fast-xml-parser	8	9.3	CRITICAL	48

טבלה 2: עשר החבילות המושפעות בעלות דירוג Betweenness הגבוה ביותר. מספר ה-`advisories` מתייחס למזהים ייחודיים המשפיעים על לפחות אחת מהגרסאות שנפתרו עבור החבילה. ציון ה-`CVSS` המוצג הוא הציון של ה-`advisory` שנבחר כבעל העדיפות הגבוהה ביותר לפי חומרה וציון.

5. דיון ומגבלות

התוצאות מראות שהמידע הטופולוגי מוסיף שכבה שאינה קיימת ברשימת `advisories` רגילה. מדדי המרכזיות מבחינים בין חבילות גשר לחבילות תשתית, וניתוח הקהילות מזהה קשרים המחברים בין אזורים שונים של הרשת. הניתוח הגלובלי הראה כי האקוסיסטם אינו מאורגן באופן אקראי: הוא מציג `hubs` הגדולים משמעותית מקו הבסיס, מאפייני `Small-World` חזקים והתפלגות `In-Degree` בעלת זנב כבד. ניסוי החוסן מאשר שלמיקום הטופולוגי יש משמעות מעשית, משום שהסרה של 2.34% מהחבילות לפי `Betweenness` פגעה בקשירות פי 2.83 מהסרה אקראית בממוצע.

למחקר שלוש מגבלות עיקריות. ראשית, גרף התלויות ומידע ה-`advisories` מקורם במאגרים חיים ונשמרו כ-`snapshots` מקומיים במועד ההרצה הסופית; לכן הממצאים משקפים את מצב המאגרים באותו מועד. שנית, איתור הפגיעויות מתבצע ברמת גרסה מדויקת, אך הניתוח הטופולוגי מאחד גרסאות שונות של אותה חבילה לצומת אחד; לכן המרכזיות מתארת את תפקיד החבילה הכולל ולא מסלול נפרד עבור כל גרסה. שלישית, חלק מהאלגוריתמים משתמשים בהטלה לא־מכוונת או בדירוג סטטי. בנוסף, ניתוח הזנב לא אפשר להעדיף `Power Law` על `Lognormal`, ולכן הרשת מתוארת כבעלת זנב כבד ולא כ-`Scale-Free` באופן חד־משמעי.

6. מסקנות

בפרויקט בנינו צינור ניתוח טופולוגי לשרשראות אספקת תוכנה והפעלנו אותו על גרף התלויות של Flowise. מדדי המרכזיות הראו שחבילות גשר וחבילות תשתית ממלאות תפקידים שונים, וזיהוי הקהילות חשף ליבה גדולה וקשרי גשר גלובליים ופנימיים.

ההשוואה ל-50 גרפים אקראיים הראתה שהרשת כוללת `hubs` והתקבצות שאינם מוסברים באמצעות מספר הצמתים והקשתות בלבד. מקדם `Small-World` של 117.6061 הראה שהרשת משלבת התקבצות מקומית

גבוהה מאוד עם מסלולים גלובליים קצרים. ניתוח התפלגות הדרגות הראה זנב כבד: Power Law נמצא עדיף על Exponential, בעוד ש-Lognormal נשאר חלופה אפשרית.

ניסוי החוסן הראה שהסרה ממוקדת של 50 חבילות בעלות Betweenness גבוהה, המהוות 2.34% בלבד מהצמתים, הקטינה את רכיב הקשירות הגדול ביותר ב-8.98%. פגיעה זו הייתה פי 2.83 מהירידה הממוצעת של 3.17% שהתקבלה בהסרה אקראית.

הניתוח האבטחתי ברמת גרסה זיהה 151 advisories ייחודיים המשפיעים על 61 צירופי חבילה-גרסה ועל 47 שמות חבילות. עשרים ושלוש מן החבילות המושפעות דורגו בעשירון העליון לפי Betweenness ו-30 ברבעון העליון. הריכוז היה גבוה באופן מובהק מהצפוי באקראי, כאשר form-data דורגה במקום השלישי ושילבה מרכזיות גבוהה עם advisory בחומרת CRITICAL ובציון 4CVSS v של 9.4.

המסקנה המרכזית היא שמידע אבטחתי ומרכזיות טופולוגית משלימים זה את זה. נתוני ה-advisory מזהים גרסאות המושפעות מפגיעויות מוכרות, ואילו הגרף מספק הקשר לגבי חשיבותן המערכתית של החבילות. השיטה מאפשרת לתעדף תיקון, ניטור והגנה במקרים שבהם פגיעות ברמת גרסה נפגשת עם מרכזיות גבוהה ברשת, וניתנת להפעלה על מערכות npm אחרות באמצעות שינוי חבילת השורש והגרסה.

מקורות

- [1] Zimmermann, M., Staicu, C. A., Tenny, C., and Pradel, M. "Small World with High Risks: A Study of Security Threats in the npm Ecosystem." USENIX Security Symposium, 2019.
- [2] Ohm, M., Plate, H., Sykosch, A., and Meier, M. "Backstabber's Knife Collection: A Review of Open-Source Software Supply Chain Attacks." DIMVA, 2020.
- [3] Albert, R., Jeong, H., and Barabási, A. L. "Error and Attack Tolerance of Complex Networks." Nature, 2000.
- [4] Saayman, J. "Post Mortem: axios npm Supply Chain Compromise." axios/axios GitHub Issue #10636, April 2, 2026.
- [5] Sonatype Research Team. "Atomic Arch npm Campaign Adds Malicious Dependency." June 11, 2026.
- [6] Clauset, A., Newman, M. E. J., and Moore, C. "Finding Community Structure in Very Large Networks." Physical Review E, 2004.
- [7] Girvan, M., and Newman, M. E. J. "Community Structure in Social and Biological Networks." Proceedings of the National Academy of Sciences, 99(12), 7821–7826, 2002.
- [8] Google Open Source Insights. "deps.dev API v3 Documentation." Accessed July 2026.
- [9] NetworkX Developers. "NetworkX Documentation." Accessed July 2026.
- [10] Watts, D. J., and Strogatz, S. H. "Collective Dynamics of Small-World Networks." Nature, 1998.
- [11] Humphries, M. D., and Gurney, K. "Network 'Small-World-Ness': A Quantitative Method for Determining Canonical Network Equivalence." PLoS ONE, 2008.
- [12] Clauset, A., Shalizi, C. R., and Newman, M. E. J. "Power-Law Distributions in Empirical Data." SIAM Review, 2009.
- [13] Alstott, J., Bullmore, E., and Plenz, D. "powerlaw: A Python Package for Analysis of Heavy-Tailed Distributions." PLoS ONE, 2014.
- [14] GitHub. "GitHub Advisory Database." Accessed July 2026.
- [15] OpenSSF. "OSV.dev Vulnerability Database and API Documentation." Accessed July 2026.